

Authentication

Field	Value
Last Updated	2026-10-02
Status	Draft

1. Current (CURRENT)

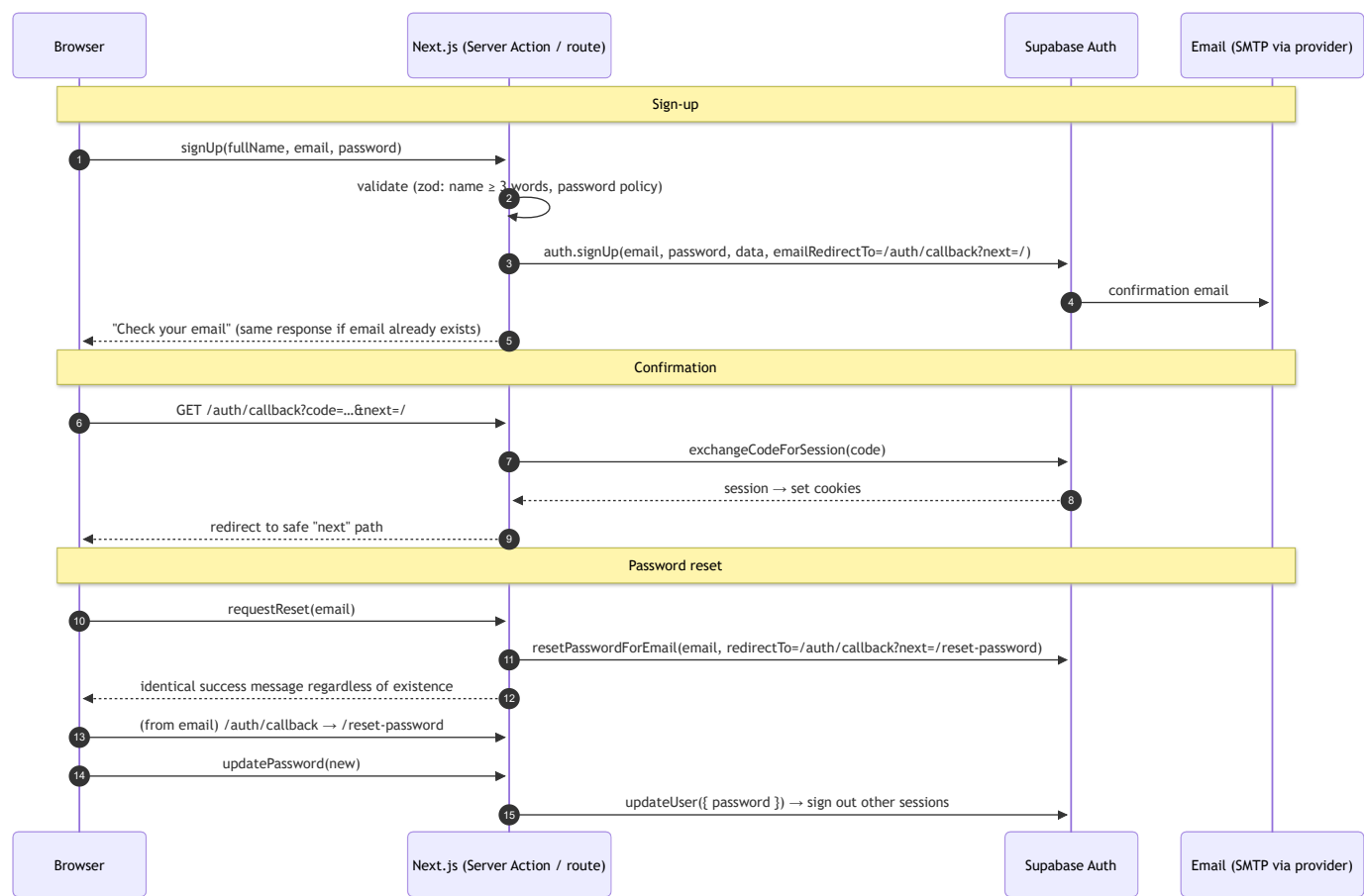
Browser-only supabase-js session in `localStorage` ; sign-up/sign-in/reset called from Client Components; server cannot identify users; validation client-side only; `check-email-exists` reveals registered emails. Details: [audit §5](#).

2. Target design

Aspect	Decision
Provider	Supabase Auth (email + password). Social login not in scope (could be added later).
Session transport	HTTP-only cookies managed by <code>@supabase/ssr</code> (server, middleware and browser clients).
Session refresh	Middleware/proxy refreshes the session on each request to app routes.
Server identity	Server code obtains the user via a verified call (<code>auth.getUser()</code> , or <code>auth.getClaims()</code> with asymmetric JWT signing keys) — never trust an unverified cookie decode.
Email confirmation	Required (<code>enable_confirmations = true</code>).
Password policy	Server-enforced: min 8, requires lower, upper, digit, symbol (matches the current UI rule) — set in Auth config. Leaked-password protection if available on the plan.

Aspect	Decision
Profile	Created by trigger on <code>auth.users</code> insert (name from sign-up metadata, locale).
Account ≠ membership	Sign-up never creates a member (BR-MBR-001).
Admin MFA	TOTP MFA required for <code>system_admin</code> and recommended for leadership (Supabase Auth MFA + AAL2 check in dashboard layout). Proposed.
Session lifetime	Access token 1 h; refresh-token rotation on; inactivity timeout per Auth settings.

3. Flows



Flow	Rules
Sign-in	Server Action; generic error on failure; specific message only for "email not confirmed" (does not leak existence beyond what Auth already returns —

Flow	Rules
	Proposed: show a "resend confirmation" link). Redirect to validated next .
Sign-out	Server Action → <code>auth.signOut()</code> → redirect home.
Email change	Secure email change (confirm on both addresses).
Account deletion	Request flow; executed by server with service role after confirmation; anonymization per privacy .
Legacy member claim	Leadership triggers a claim email to <code>legacy_claim_email</code> ; the link (signed, single-use, expiring) lets the recipient sign in/sign up and links the member record (<code>claim_legacy_member</code>).

4. Route protection

Route group	Protection
Public	None
(auth) pages	Redirect signed-in users away
<code>/account/*</code>	Middleware redirects unauthenticated users to <code>/login?next=...</code> ; pages call <code>requireUser()</code>
<code>/dashboard/*</code>	<code>requireUser()</code> + <code>requireAnyPermission([...])</code> in the layout; each page/action checks its own permission; MFA AAL2 for admin pages

5. Auth configuration (to version in `supabase/config.toml`)

Setting	Value
<code>site_url</code>	<code>http://127.0.0.1:3000</code> (local); env-specific on hosted projects
<code>additional_redirect_urls</code>	Local, preview wildcard (<code>https://*-<team>.vercel.app/**</code>), production

Setting	Value
	domain
enable_signup	true
[auth.email] enable_confirmations	true
double_confirm_changes / secure email change	true
minimum_password_length	8
password_requirements	lower_upper_letters_digits_symbols
[auth.rate_limit]	Defaults reviewed; email sends limited per hour
[auth.email.smtp]	Hosted: provider SMTP credentials (from secrets). Local: Mailpit
[auth.email.template.*]	supabase/templates/*.html (bilingual, branded)
[auth.mfa.totp]	enroll/verify enabled

The current `config.toml` contains none of these (CLI defaults apply) — fixing that is a Phase 1 task.